

1. sql 注入预编译的原理是什么？

预编译又称为预处理，顾名思义，就是为代码编译做的预备工作很多情况下，一条 SQL 语句可能会反复执行，或者每次执行的时候只有个别的参数值不同，预编译就是将 sql 语句中的值用占位符?替代，即将 SQL 语句模板化或者参数化，SQL 语句先交由数据库预处理，构建语法树，再传入真正的字段值进行执行，无论后续向模板传入什么参数，这些参数仅仅被当成字符串进行查询处理，因此，杜绝了 sql 注入的产生

2. sqlmap --os-shell 原理以及前提条件是什么？

原理：对于 mysql 数据库来讲，--os-shell 的本质就是写入两个 shell 文件，其中的一个可以让我们用来执行命令，而另外一个，如果在网站访问的话，可以让我们可以上传文件。

前提条件：root 权限，知道绝对路径，GPC 关闭，Secure_file_priv 参数为空或者为指定路径。

3. sql 注入 sleep() 函数被过滤如何解决？

替换其他函数，如 benchmark() 函数

4. mysql 写 shell，如果不知道网站绝对路径，怎么办？

以下方式可以获得网站绝对路径：

单引号爆路径、错误参数值爆路径、通过搜索引擎获取、测试文件获取路径
配置文件获取路径、nginx 文件类型错误解析爆路径、phpmyadmin 爆路径、配合
远程代码执行漏洞

5. java 反序列化原理是什么？

Java 中的 ObjectOutputStream 类的 writeObject() 方法可以实现序列化，

其作用把对象转换成字节流，便于保存或者传输，而 `ObjectInputStream` 类的 `readObject()` 方法用于反序列化，作用就是把字节流还原成对象

6. 了解 shrio 反序列化吗？

shiro 反序列化主要是 Apache shiro 提供了一个 `remember` 的一个功能，用户登录成功后会生成经过加密并编码的 `cookie`，保存在浏览器中方便用户的日常使用，而服务器对 `cookie` 的处理流程就是先获取浏览器上保存的 `cookie`，然后将其 `bs64` 解码，再进行 AES 解密，再将其反序列化进行校验，而漏洞就是出现在这里，我们都知道 AES 它是一个硬编码，他是有默认密钥的，如果程序员没有去修改或者过于简单，那我们就可以进行 `cookie` 重构，先构造我们的恶意代码，然后将恶意代码进行序列化，然后 AES 加密（密钥我们已经爆破出来了），再进行 `bs64` 编码，形成我们新的 `cookie`，而服务器在处理时就会按照刚才的处理流程，就会在服务端触发我们构造的恶意代码。

7. shrio550 和 shiro721 的区别？

Shiro550 使用已知密钥碰撞，只要有足够密钥库（条件较低），不需要 `Remember Cookie`，Shiro721 的 `ase` 加密的 `key` 基本猜不到，系统随机生成，可使用登录后 `rememberMe` 去爆破正确的 `key` 值，即利用有效的 `RememberMe Cookie` 作为 `Padding Oracle Attack` 的前缀，然后精心构造 `RememberMe Cookie` 值来实现反序列化漏洞攻击，难度高。

8. fastjson 不出网如何利用？

`TemplatesImpl` 利用链：

`TemplatesImpl` 利用链的利用条件比较苛刻，服务端使用 `parseObject()` 时，必须使用如下格式才能触发漏洞：`JSON.parseObject(input, Object.class, Feature.SupportNonPublicField);`

服务端使用 `parse()` 时，需要 `JSON.parse(text1, Feature.SupportNonPublicField)`，这是因为 `com.sun.org.apache.xalan.internal.xsltc.trax.TemplatesImpl` 需要赋值的一些属性为 `private` 属性，要满足 `private` 属性的数据。

BCEL 不出网打法:

bcel 攻击则是利用 tomcat 的 BasicDataSource 链

编译 poc, 将 poc 的 class 字节码转化为 bcel 然后发送 payload

9. 蚁剑/菜刀/冰蝎/哥斯拉的相同与不相同之处?

相同: 都是用来连接 Web Shell 的工具

不同: 相比于其他三款, 冰蝎有流量动态加密

10. msf 和 cs 流量特征?

Msf:

端口号: msf 默认使用 4444 端口作为反向连接端口

数据内容: msf 数据包通常包含特定字符串: ("meterpreter"、"revshell"等)

CS:

基本特征: 心跳包

请求特征: 下发的指令, url 路径, 老版本固定的 ua 头

源码特征: checksum8 (92L 93L)

如果进行二开魔改后的 cs, 可提取样本

11. windows 或 linux 被植入后门文件, 讲一下你的排查流程?

检查系统日志, 检查系统用户, 查看是否有异常的系统用户, 检查异常进程, 检查隐藏进程, 检查异常系统文件, 检查系统文件完整性, 检查网络, 检查系统计划任务, 检查系统后门, 检查系统服务

12. 判断 sql 注入是攻击还是误报?

首先看响应包的长度, 366 成功, 332 失败, 然后看 SQL 语句详细信息里看请求体,

看 url, 如果是很明显的 sql 语句, 里面加一些单引号, 分号, 双重破折号, 大概率为攻击, 如果只是多了一些字母, 数字就是误报。

查看攻击样本

看它一定时间内同一 ip 地址访问的次数、访问的内容

看它访问的时间（在凌晨俩三点访问邮箱输错账号密码）

看它 Ip 源地址（外国 ip 的话有可能就是使用了代理池）

数据头中包含的 url，可以拿到沙箱测试，如果这个网站没有问题就是误报

13. 内网告警应该如何处理，流程是怎么样子的？

具体定位到哪台机器，报警说明知道具体漏洞类型，打相应补丁。利用 webshell 或者是 shell 查杀工具查杀，查看 tmp 目录下是否有带有免杀的木马。彻底清除。再到全流量分析的机子上看，是否有经过其他的机器。拿到攻击 ip 之后到线上的一些网站查看主机类型，比如 360 或者微步上，查看是否是傀儡机，vps 跳板，或者是国内个人云主机。如果是个人云主机，就可以通过 whois 查看是否有最近绑定的域名，或者绑定者的邮箱。知道邮箱之后就可以反查询出 qq 号说多少，再利用社工查询到手机号，到一个知名的网站或知名软件上查询这个手机号有没有注册过什么网站，可以去这些网站通过撞库的方法登入，这样就可以拿到这个攻击者的身份证，学校，地址这些了。

14. 怎么判断是不是误报？

- 首先你要知道你管辖的局点网段信息
- 如果攻击 IP 和被攻击 IP 是同一个网段的，那就可能是由于业务特征被安全产品规则库判定为是攻击，而产生了误报
- 如果攻击 IP 不是本局点的网络，这个就可能是真正的攻击
- 主要看 IP 访问次数，攻击源有没有共性，看数据包内容

15. 打点一般会用什么漏洞？

优先以 java 反序列化这些漏洞像 shiro、fastjson、weblogic、用友 oa 等进行打点，随后再找其他脆弱性易打进去的点。因为 javaweb 程序运行都是以高权限运行，部分可能会降权。

16. 正向代理和反向代理区别？

正向代理是一个位于客户端和原始服务器之间的服务器，为了从原始服务器取得内容，客户端向代理发送一个请求并指定目标(原始服务器)，然后代理向原始服务器转交请求并将获得的内容返回给客户端。

反向代理，客户端是无感知代理的存在，以代理服务器来接受 internet 上的连接请求，然后将请求转发给内部网络上的服务器，并将从服务器上得到的结果返回给 internet 上请求连接的客户端。此时代理服务器对外就表现为一个服务器。

17. 内网横向 psexec 和 wmic 的区别？

Psexec 会产生大量日志，而 wmic 不会

18. 内网认证协议有哪些？认证原理分别是什么？

内网认证协议：NTLM 协议、Kerberos 协议

NTLM 协议认证原理：

NTLM 协议采用 Challenge/Response 认证机制：

- 1.协商：双方先确定一下传输协议的版本等各种信息
- 2.质询：这一步是挑战/响应的关键一步
- 3.验证：对质询的最后一个结果进行验证，验证通过之后，即允许访问资源

Kerberos 协议认证原理：

- 1.首先 Client 向域控制器 DC 请求访问 Server，DC 通过去 AD 活动目录中查找依次区分 Client 来判断 Client 是否可信。
- 2.认证通过后返回 TGT 给 Client，Client 得到 TGT (Ticket Granting Ticket)。
- 3.Client 继续拿着 TGT 请求 DC 访问 Server，TGS 通过 Client 消息中的 TGT，判断 Client 是否有访问权限。
- 4.如果有，则给 Client 有访问 Server 的权限 Ticket，也叫 ST (Service Ticket)。
- 5.Client 得到 Ticket 后，再去访问 Server，且该 Ticket 只针对这一个 Server 有效。
- 6.最终 Server 和 Client 建立通信。

19. 黄金票据和白银票据的区别？

	黄金票据	白银票据
访问权限	伪造TGT，可以获取任何Kerberos服务权限	伪造TGS，只能访问指定的服务
加密方式	由Kerberos的Hash加密	Silver Ticket由服务账号Hash加密
认证流程	需要访问域控认证，属于第二步认证	直接和服务器认，最后一步认证

20. 拿到 webshell 不出网情况下怎么办？

分两种情况讨论：

如果是都不出网的情况，则上传工具正向连接，如 Reg

如果限制了部分协议不出网，则探测出网协议，采用隧道方式